

新形势下准入控制技术的探究与应用

北京江南天安科技有限公司
焦宏亮



信息安全的重要性

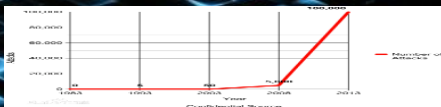


信息安全态势



黑客攻击危及国家安全

APT（高级持续性攻击）日益增加，2014年以来，APT攻击事件集中在政府（28%）、金融（16%）和互联网电信（13%），能源（12%）等行业，主要是面向攻击附加值较高的企业和关键国家基础设施。
永恒之蓝-勒索病毒，波及全球100多个国家，我国校园网、公安内网等关键国家基础设施受灾严重。



1 信息安全关乎国家安全，我国关键信息基础设施面临新时期严峻的网络攻击风险

- 1、应对严峻的网络安全态势，要树立正确的网络安全观，加快构建关键信息基础设施安全保障体系，全天候、全方位感知网络安全态势，增强网络安全防御能力和威慑能力。
- 2、网络安全是动态的而不是静态的。信息技术变化越来越快，过去分散独立的网络变得高度关联、相互依赖，网络安全的威胁来源和攻击手段不断变化，那种依靠装几个安全设备和安全软件就想永保安全的想法已不合时宜，需要树立动态、综合的防护理念。
- 3、维护网络安全，首先要知道风险在哪里，是什么样的风险，什么时候发生风险，正所谓“聪者听于无声，明者见于未形”。

信息安全态势

网络安全法获高票通过 明确加强个人信息保护

十二届全国人大常委会第二十四次会议11月7日上午经表决通过了《中华人民共和国网络安全法》

2015年6月

十二届全国人大常委会第十五次会议对网络安全法草案进行首次审议

2016年6月

十二届全国人大常委会第二十二次会议对网络安全法草案进行第二次审议

2016年10月31日

网络安全法草案提交十二届全国人大常委会第二十四次会议进行第三次审议

网络安全法的出台先后经过了全国人大常委会的三次审议

网络安全法共有7章79条
内容上有6方面突出亮点

1

明确了网络空间主权的原則

2

明确了网络产品和服务提供者的安全义务

3

明确了网络运营者的安全义务

4

进一步完善了个人信息保护规则

5

建立了关键信息基础设施安全保护制度

6

确立了关键信息基础设施重要数据跨境传输的规则

2 《网络安全法》实施 明确网络安全等级保护制度

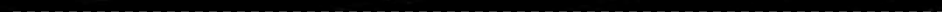
2016年，人大审议通过《中华人民共和国网络安全法》是我国落实网络安全战略的重大里程碑。

- 1、《中华人民共和国网络安全法》自2017年6月1日起施行。
- 2、开启了依法治网的崭新局面，成为依法治国顶层设计下一项共建共享的路径实践。
- 3、关键信息基础设施的运营者不履行网络安全保护义务的，由有关主管部门责令改正，给予警告；拒不改正或者导致危害网络安全等后果的，处十万元以上一百万元以下罚款，对直接负责的主管人员处一万元以上十万元以下罚款。
- 4、《网络安全法》强调在网络安全等级保护制度的基础上，对关键信息基础设施实行重点保护，明确关键信息基础设施的运营者负有更多的安全保护义务，并配以国家安全审查、重要数据强制本地存储等法律措施，确保关键信息基础设施的运行安全。



02

终端安全的严峻性



勒索病毒 (WannaCry和Petya)



You became victim of the PETYA RANSOMWARE!

The harddisks of your computer have been encrypted with an military grade encryption algorithm. There is no way to restore your data without a special key. You can purchase this key on the darknet page shown in step 2.

To purchase your key and restore your data, please follow these three easy steps:

1. Download the Tor Browser at "<https://www.torproject.org/>". If you need help, please google for "access onion page".
2. Visit one of the following pages with the Tor Browser:

<http://petya.onion/g>
<http://petya.onion/g>

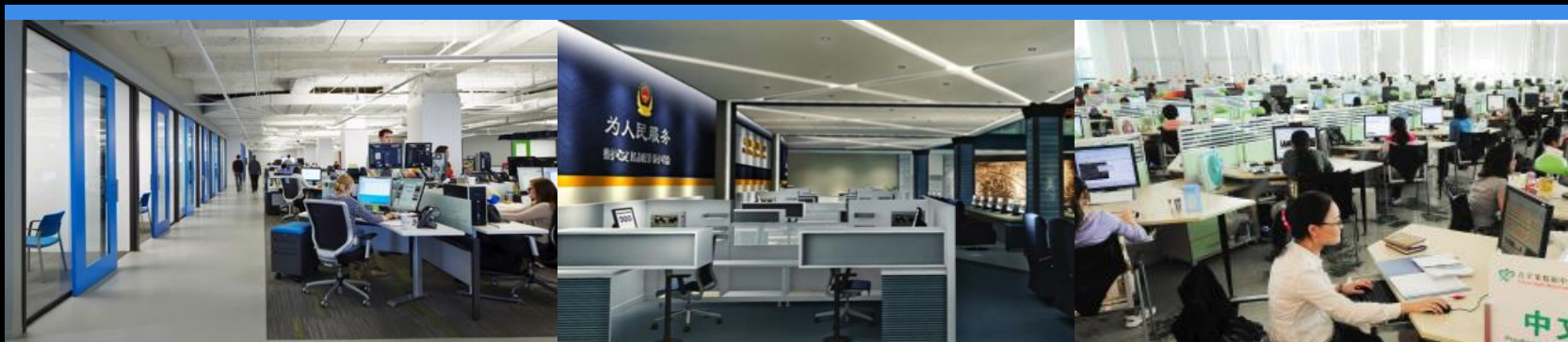
3. Enter your personal decryption code there:

a6
nF

If you already purchased your key, please enter it below.

Key: _

机密数据泄露



软件开发

涉密网/非涉密网

运维外包



U盘泄密



打印泄密



外发泄密



设备丢失泄密



应用服务器泄密

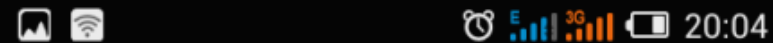
从源头加密数据，管控各种泄密隐患，重要文件“拿不走，看不了，可追踪”。

BYON (随身Wifi或WLAN热点)



插入电脑，手机立即免费上网

只需插入一台可上网的电脑，即可将电脑的网络变成WiFi，
手机即刻使用高速宽带网络免费上网。



网络共享与便携式热点

WLAN 热点

便携式热点 K-A380 已启用

打开

USB 共享网络

USB 未连接

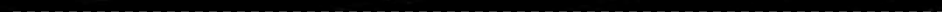
网络共享与便携式热点设置

IPv4



03

终端管理的复杂性



终端运维

资产管理

收集、统计和分析硬件资产、软件资产、License资产和用户信息

基线管理

按照安全基线要求，集中配置各种桌面策略，确保终端安全达到一致性和合规性

补丁管理

主动评估和修补系统漏洞

软件分发

分发各种办公应用软件

边界检查管理

检测企业擅自架设违规互联网出口

防病毒/防火墙管理

通过统一防火墙加强系统端口管理，防止恶意攻击

电源管理

对桌面的统一电源策略管理，达到节能减排和绿色IT的目的

移动介质管理

对移动介质的权限进行控制，保障重要部门的数据安全性

报表管理

对管理要求的审计和报警数据进行全网自动收集集中展示

远程支持

在确认发现桌面异常的情况下，桌面用户可主动申请或管理员主动远程对桌面进行维护

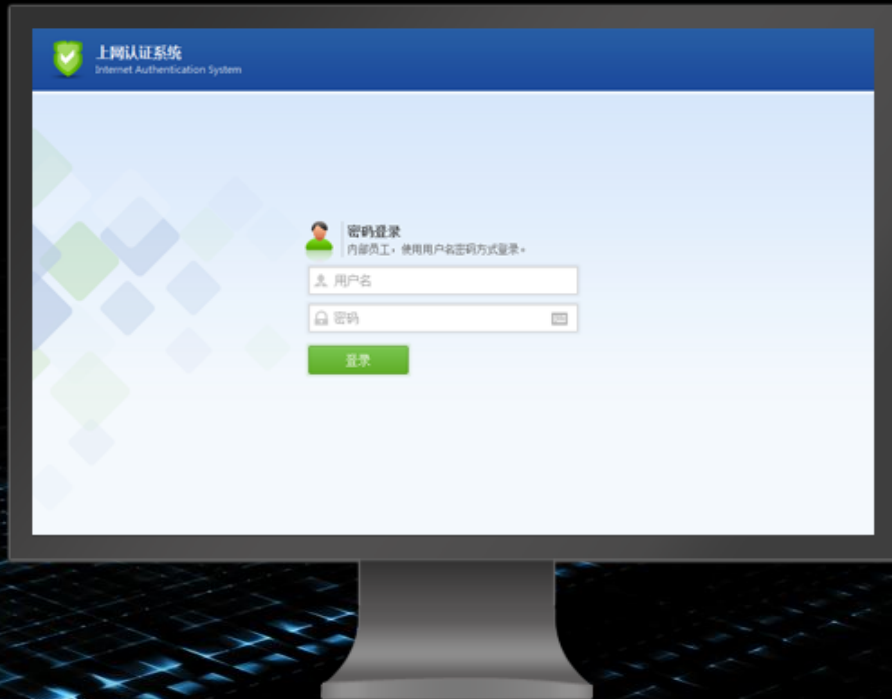
自助工具

给终端用户提供简单的终端情况查询与自助的维护工具

其他功能

实名制注册的认证机制
客户端代理上网配置功能

终端体验 (SSO单点登录)



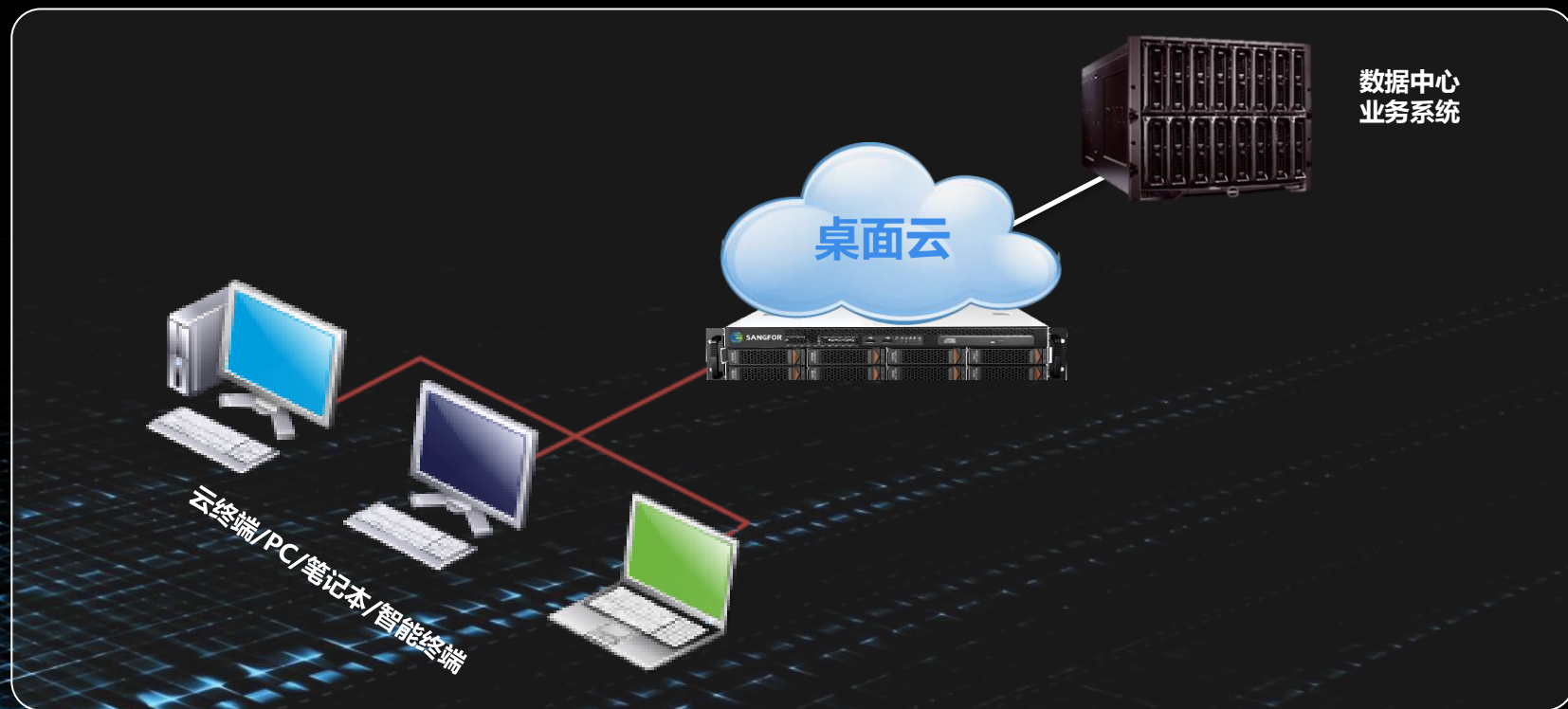
认证
同步



终端体验（临时访客）



终端新技术



BYOD移动终端



哑终端和视频监控





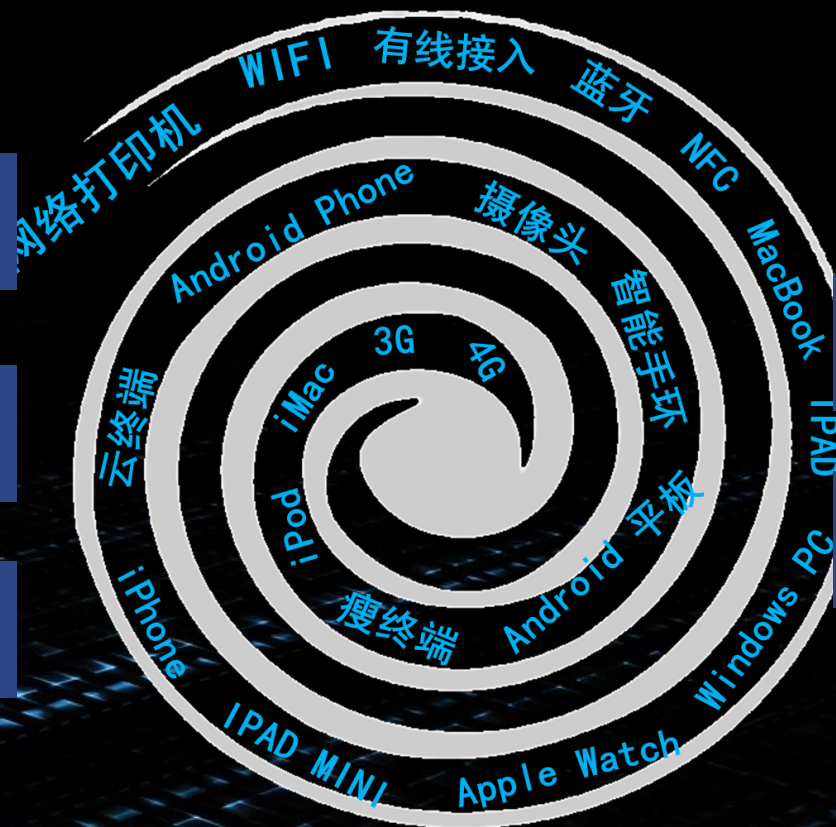
新形势下终端接入的挑战

终端接入的新挑战

接入形式多样

接入设备多样

BYON越来越多



法规要求严格

未知风险加大

终端接入的典型盲区

1	接入了什么设备
2	这些设备在哪里
3	谁在使用这些设备
4	他们的安全性怎样





05

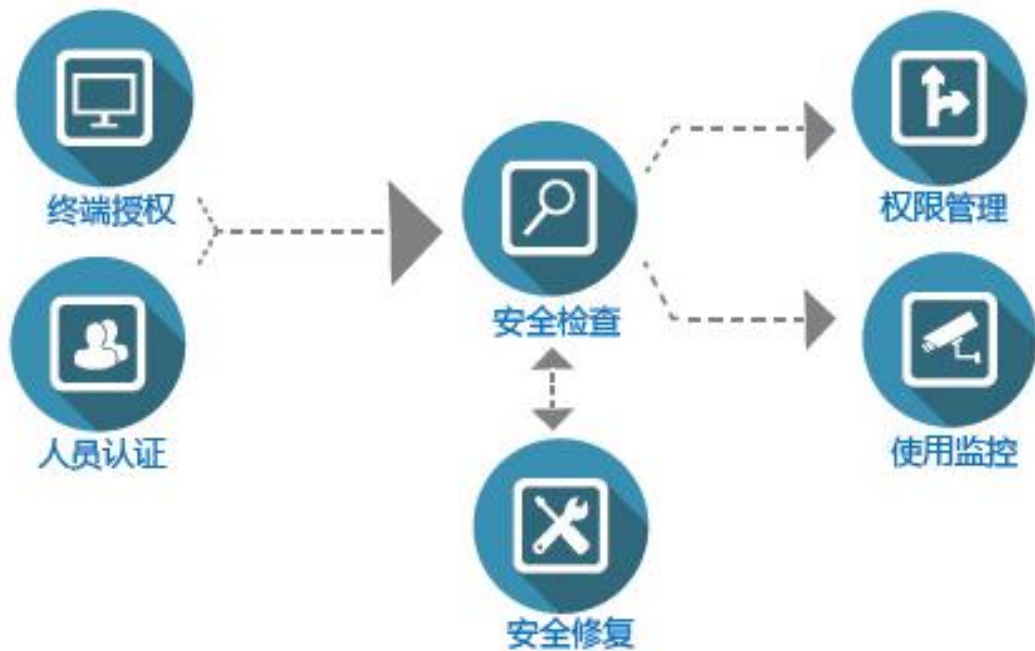
PC端的准入控制技术



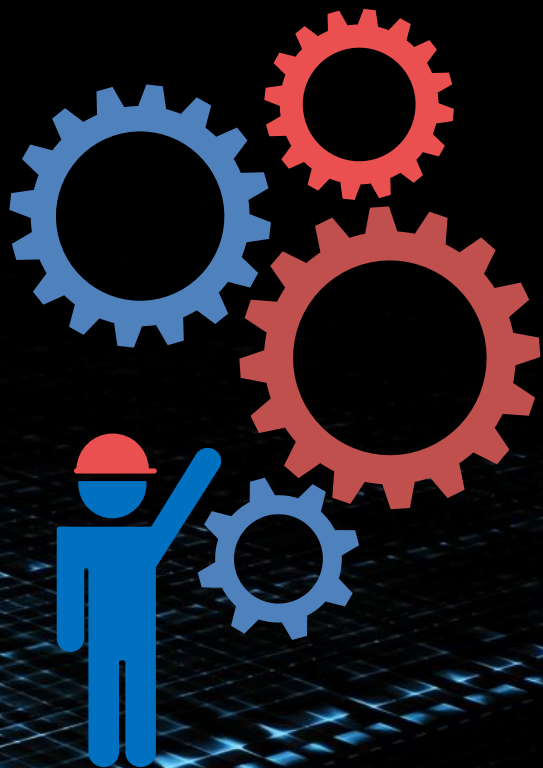
核心功能



准入流程



接入人员合法可控（AD域、OTP动态令牌——国产加密机）



认证合法方可入网
来宾入网专用通道
非法人员禁止入网

提高接入设备安全性



非授权设备禁入
满足入网安全基线

终端数量和类别清晰



终端数量清晰

终端类型明晰

资产台账准确

安全事件可定位



追溯到设备、位置、人员
自动或手动隔离

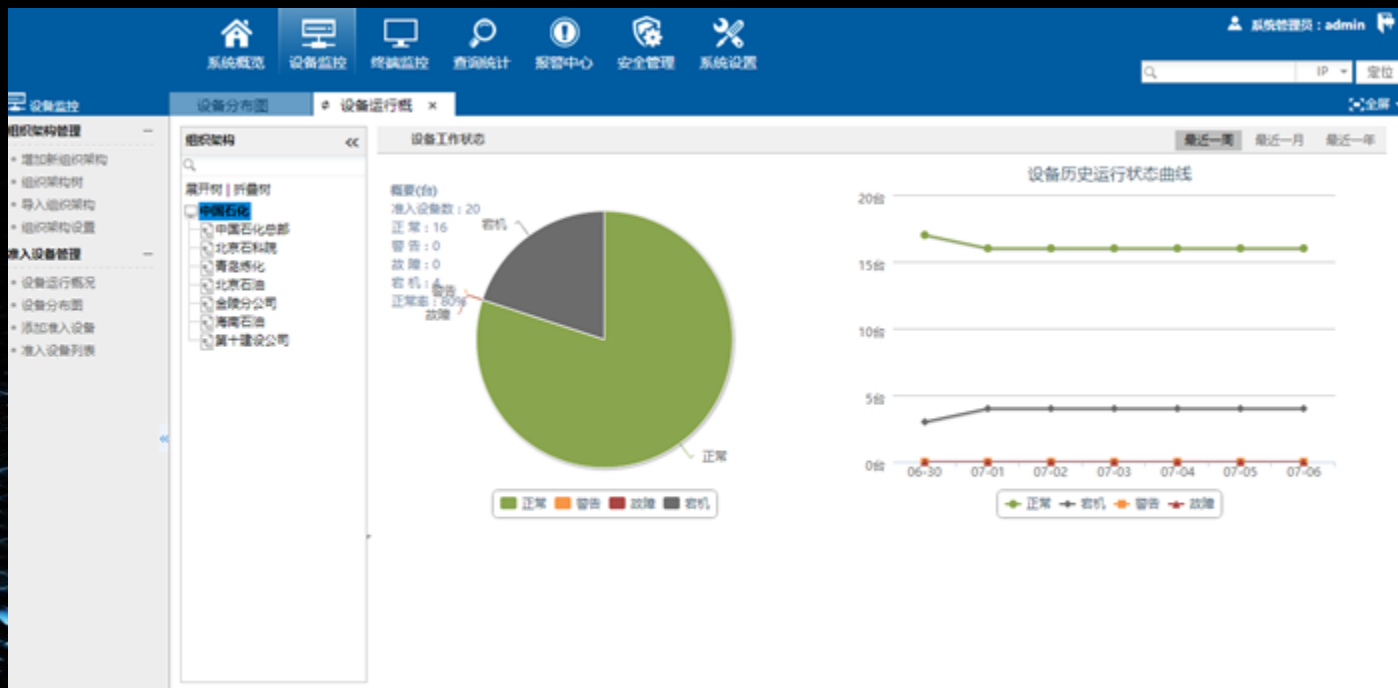
集中管理平台

基于全局查看各企业设备在线状态，并根据设备在线率、终端准入率等进行排名统计



集中管理平台

基于全局查看各企业设备在线状态，提供设备历史运行状态曲线图



集中管理平台

基于全局查看各企业终端运行状态，包括终端总数、准入数量、准入安装率



集中管理平台

可直观查看各企业设备在线状况，包括IP、工作模式和是否在线

系统概览 设备监控 终端监控 查询统计 报警中心 安全管理 系统设置

系统管理员: admin

查询统计

设备分布图 设备运行日志

组织架构

- 中国石化总部
- 北京石科院
- 青岛炼化
- 北京石油
- 金陵分公司
- 海南石油
- 第十建设分公司

设备运行日志

设备	IP	设备名称	准入模式	运行模式	运行状态	单位名称
第十建设光谷有线策略路由二期主设备	10.153.153.24	第十建设光谷有线策略路由二期主设备	策略路由	正常模式	●	第十建设分公司
第十建设光谷有线策略路由二期主设备	10.153.153.23	第十建设光谷有线策略路由二期主设备	策略路由	正常模式	●	第十建设分公司
第十建设青岛有线策略路由二期主设备	10.153.153.21	第十建设青岛有线策略路由二期主设备	策略路由	正常模式	●	第十建设分公司
第十建设青岛有线策略路由二期主设备	10.153.153.20	第十建设青岛有线策略路由二期主设备	策略路由	正常模式	●	第十建设分公司
海南石油一期有线主设备	10.193.60.82	海南石油一期有线主设备	--	--	●	海南石油
海南石油一期有线主设备	10.193.60.81	海南石油一期有线主设备	MVG	正常模式	●	海南石油
金陵分公司一期无线主设备	10.108.61.134	金陵分公司一期无线主设备	策略路由	正常模式	●	金陵分公司
金陵分公司一期无线主设备	10.108.61.130	金陵分公司一期无线主设备	策略路由	正常模式	●	金陵分公司
金陵分公司一期有线主设备	10.108.61.144	金陵分公司一期有线主设备	MVG	正常模式	●	金陵分公司
金陵分公司一期有线主设备	10.108.61.140	金陵分公司一期有线主设备	MVG	正常模式	●	金陵分公司
北京石油一期有线主设备	10.177.3.90	北京石油一期有线主设备	MVG	正常模式	●	北京石油
北京石油一期有线主设备	10.177.3.89	北京石油一期有线主设备	MVG	正常模式	●	北京石油
青岛炼化二期有线主设备	10.12.100.154	青岛炼化二期有线主设备	MVG	正常模式	●	青岛炼化
青岛炼化二期有线主设备	10.12.100.153	青岛炼化二期有线主设备	MVG	正常模式	●	青岛炼化

每页显示 20 条记录 共 20 条 当前页为: 第 1 页 共 1 页 刷新 1 页

集中管理平台

实时查看各企业设备报警信息，包括网络中断、注册率和安检通过率等

The screenshot displays the 'Real-time Alarm Monitoring' (实时报警监控) interface. The top navigation bar includes icons for Home, Device Monitoring, Terminal Monitoring, Query Statistics, Alarm Center, Security Management, and System Settings. The left sidebar shows the 'Alarm Center' (报警中心) menu with options like 'Alarm View' (报警查看), 'Alarm Settings' (报警设置), and 'Alarm Template Management' (报警模板管理). The main content area shows a table of real-time alarms.

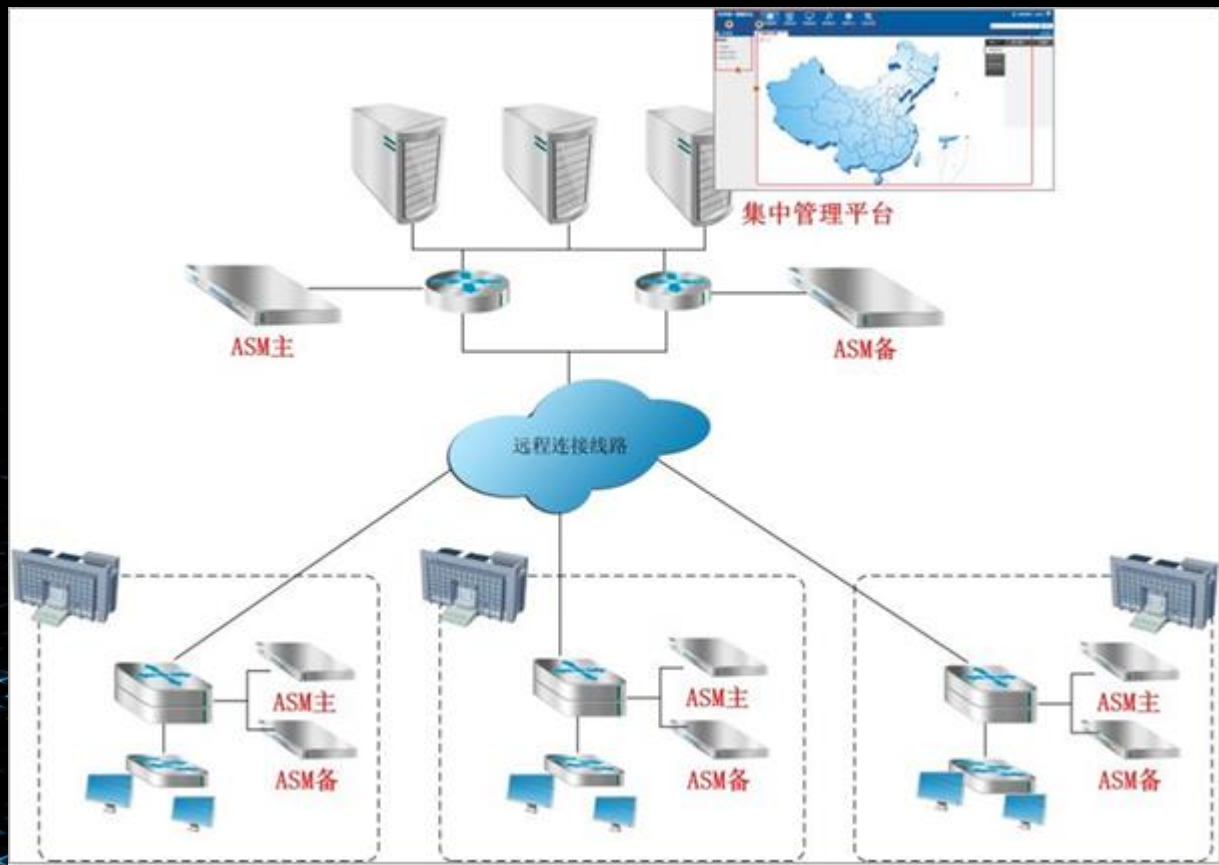
查看	报警级别	来源	报警内容	报警时间
	重要	系统	[中国石化/第十建设有限公司]注册率为[4%]	2016-07-06 03:30:24
	重要	系统	[中国石化/第十建设有限公司]安检通过率[1.17%]	2016-07-06 03:30:24
	紧急	第十建设有限公司有线策略路由二期警设备(10.153.153.21)	PING不通准入设备[10.153.153.21]	2016-07-06 11:32:21
	紧急	海南石油一期有线警设备(10.193.60.82)	PING不通准入设备[10.193.60.82]	2016-07-06 11:32:03
	紧急	第十建设有限公司有线策略路由二期主设备(10.153.153.20)	PING不通准入设备[10.153.153.20]	2016-07-06 11:31:57
	紧急	总部1号楼一期有线警设备(10.7.2.198)	PING不通准入设备[10.7.2.198]	2016-07-06 11:31:55
	重要	系统	[中国石化/第十建设有限公司]注册率为[4%]	2016-07-05 03:31:05
	重要	系统	[中国石化/第十建设有限公司]安检通过率[1.17%]	2016-07-05 03:31:05
	紧急	第十建设有限公司有线策略路由二期警设备(10.153.153.21)	PING不通准入设备[10.153.153.21]	2016-07-05 23:32:11
	紧急	海南石油一期有线警设备(10.193.60.82)	PING不通准入设备[10.193.60.82]	2016-07-05 23:31:53
	紧急	第十建设有限公司有线策略路由二期主设备(10.153.153.20)	PING不通准入设备[10.153.153.20]	2016-07-05 23:31:47
	紧急	总部1号楼一期有线警设备(10.7.2.198)	PING不通准入设备[10.7.2.198]	2016-07-05 23:31:45
	重要	系统	[中国石化/第十建设有限公司]注册率为[4%]	2016-07-04 03:30:46
	重要	系统	[中国石化/第十建设有限公司]安检通过率[1.17%]	2016-07-04 03:30:46
	紧急	第十建设有限公司有线策略路由二期警设备(10.153.153.21)	PING不通准入设备[10.153.153.21]	2016-07-04 23:32:52
	紧急	海南石油一期有线警设备(10.193.60.82)	PING不通准入设备[10.193.60.82]	2016-07-04 23:32:34

成功案例

某大型央企的实施内容和效果

- 总部及各分支机构进行双机部署
- 部署“集中管理平台”统一管理
- 部署准入控制设备超1000台
- 部署终端约60万

- 适应了现有网络设备和结构
- 确保了实名制审计
- 完善了内网接入安全
- 内控制度得以落实





06

物联网的准入控制技术



物联网的安全风险

根据Gartner的研究报告显示，到2020年，全球将有约260亿个独立的智能设备连接至互联网。与此同时，一项物联网研究报告指出，70%的IoT装置有遭受攻击的风险，而平均每一产品有25项安全弱点。中国5000多个重要的工业控制系统中，95%以上的工控系统操作系统均是采用是国外产品，这意味着国内的生产系统很容易受到国外黑客的攻击。



物联网规模庞大、分支较多、IPC地理位置分散，人为监管困难



攻击者可轻易连接到核心业务系统，并通过攻击影响业务正常运行



数据库系统内视频、图像等敏感信息外泄将会造成重大损失

万物互联
(IoE)

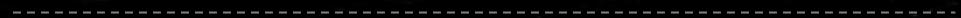
物联网的准入控制





07

摄像头的准入控制技术



黑天鹅事件



设备漏洞

设备弱口令

被非法控制

摄像头被非法替换

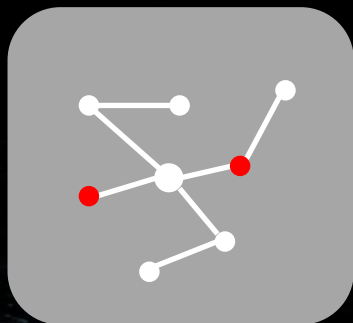


摄像头非法替换

进行网络入侵

非法设备获取数据

非法外联



私接Router

私接HUB

私接WIFI

网络边界扩展，
引入不确定性。

管理平台脆弱



系统漏洞

弱口令

视频管
理系统
被攻击
利用

管理平台脆弱



系统漏洞

弱口令

视频管
理系统
被攻击
利用

非法人员操作



非法人员入网

入网人员无追溯

非法人员进行
操作

应对之法



防止摄像头非法替换

扫描发现



采集标识

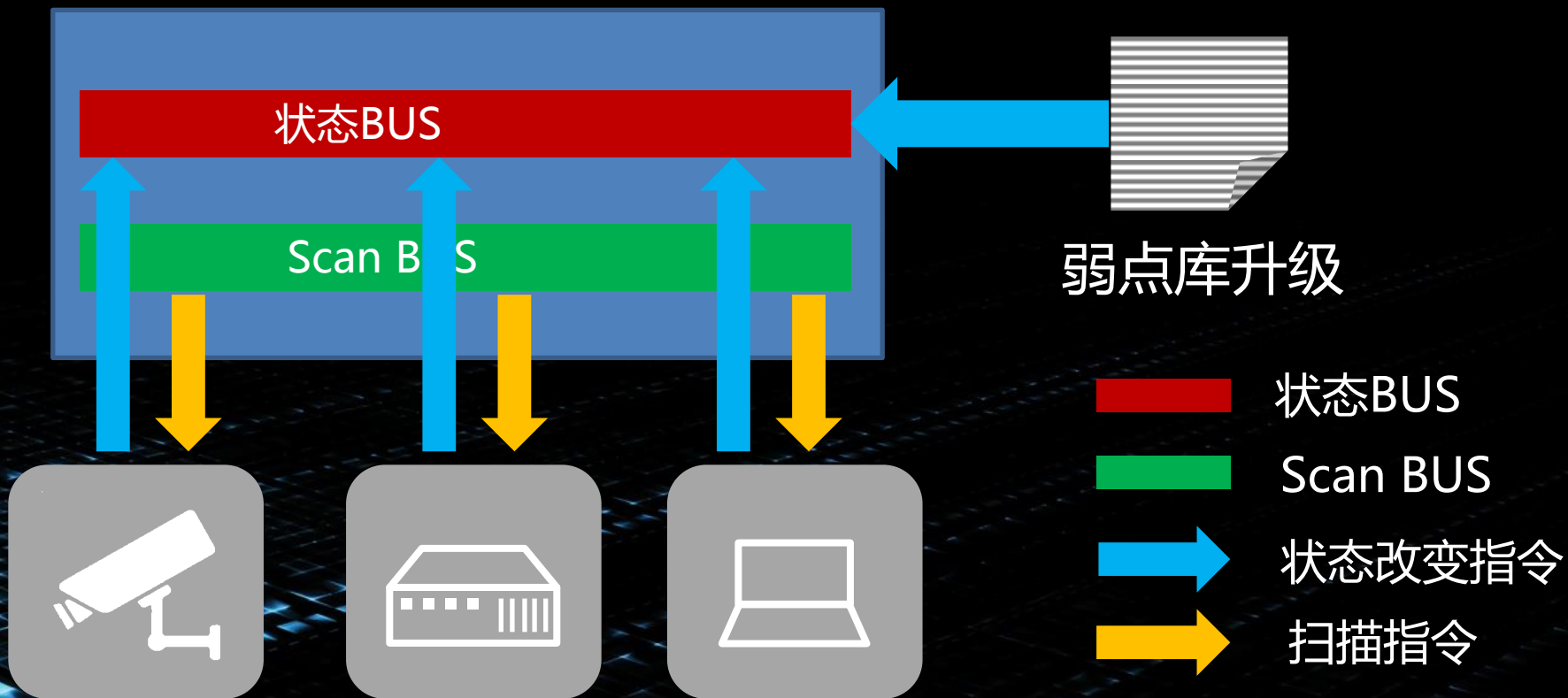


伪造识别

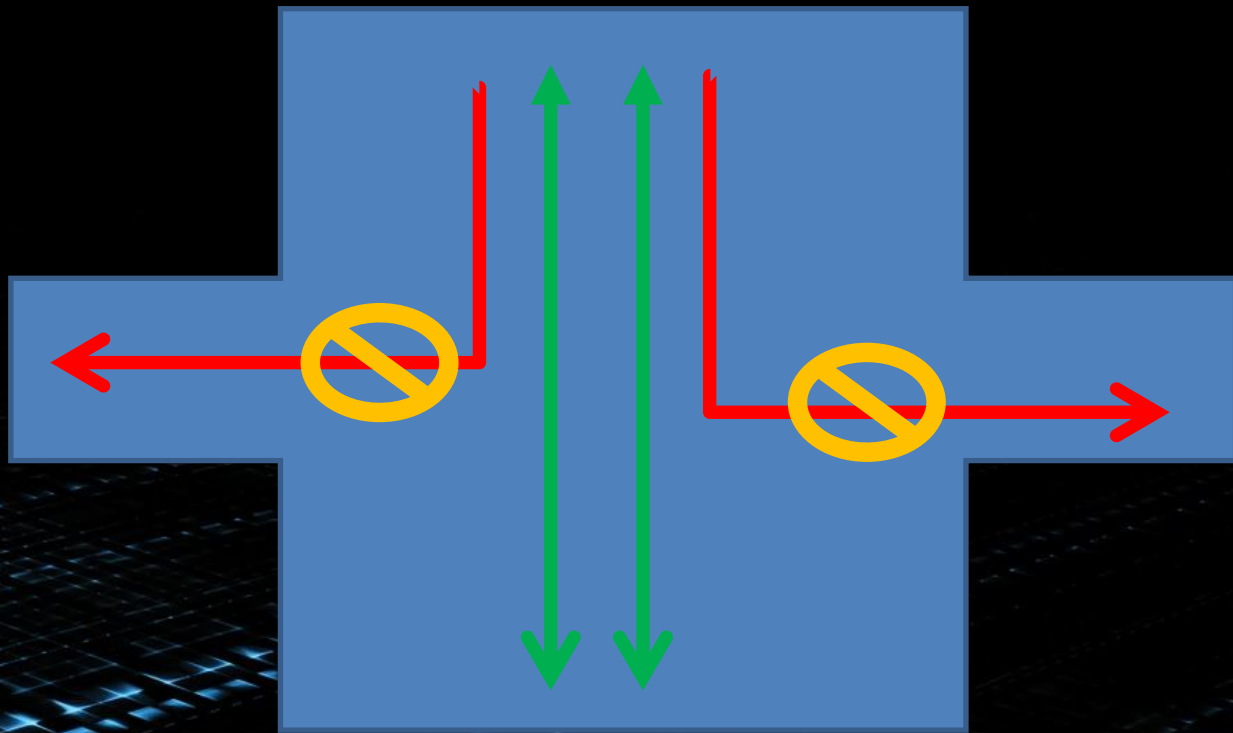


阻断 报警

实时弱点发现



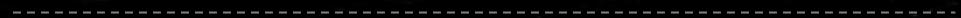
流量合法性监控



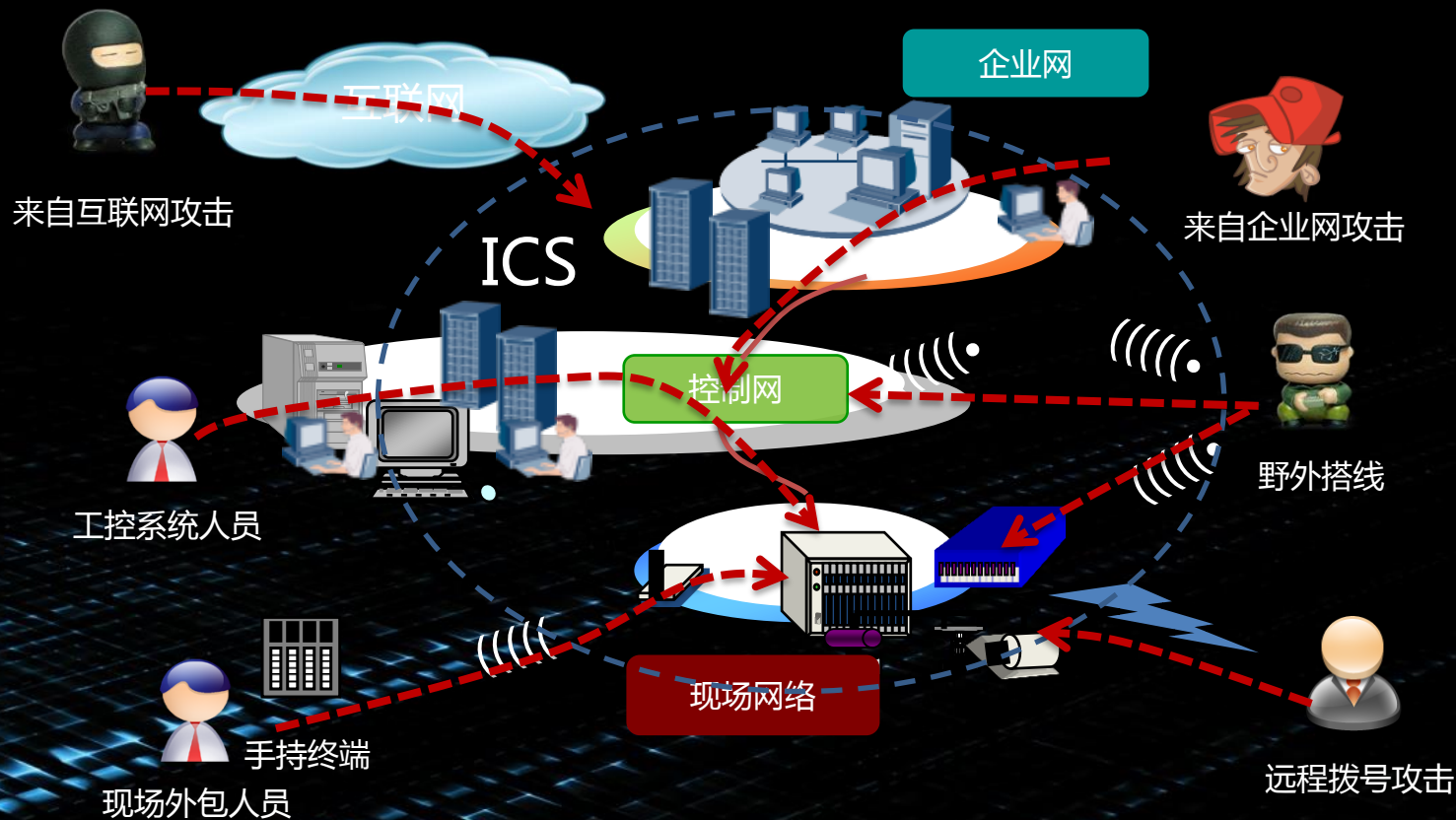


08

工控网的准入控制技术



工控网的安全风险



工控网的整体防护

网络透视



网络结构



哑终端管理

MDM



应用管理



访客认证

连续安全



持续安检

工控网的重点防护（U盘和非法外联）

1、对U盘使用进行管控，并对U盘数据进行加密

2、对移动终端进行应用程序、安全配置管理

3、阻止终端非法外联，访问域权限管理

4、对资产信息采集，汇总资产变更情况



智慧医疗的准入控制技术

公共或专用Wifi的准入控制



移动设备的准入控制

中国联通 下午2:48

< 用户密码认证

lsl

...

+ 高级

> 下一步

12345678

中国联通 下午2:48

设备注册

请选择[所属部门].....

请填写真实姓名, 16个字符

请填写正确的电话号码

邮箱地址

请选择[设备类型].....

请选择[设备位置].....

上午10:41

安检

100%

检查完成, 正在处理数据...

管理员电话:12345678

上午10:46

100 您的电脑完全符合检查规则, 可以正常使用网络了!

- ✓ 必须安装软件检查 符合管理员要求
- ✓ 必须运行进程检查 符合管理员要求
- ✓ 禁止安装软件检查 符合管理员要求
- ✓ 禁止运行进程检查 符合管理员要求
- ✓ 杀毒软件检查 符合管理员要求

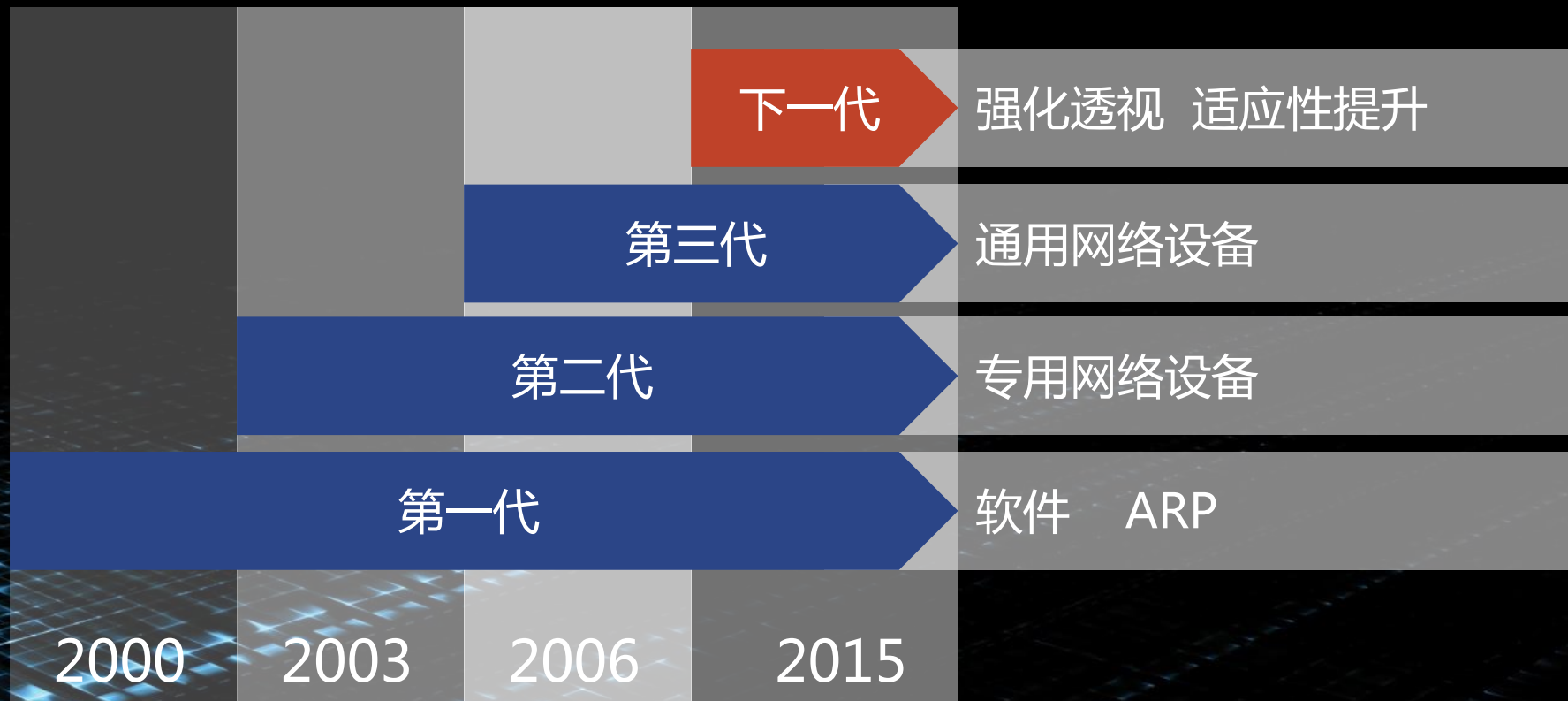
重新认证



下一代的准入控制技术



不断发展的准入控制技术



下一代准入控制技术是当前热点

热

下一代

准入技术快速部署、多类型终端、多维度透视

第三代

监控持续性弱，存在管控盲区

第二代

非特定型号的网络设备无法管理

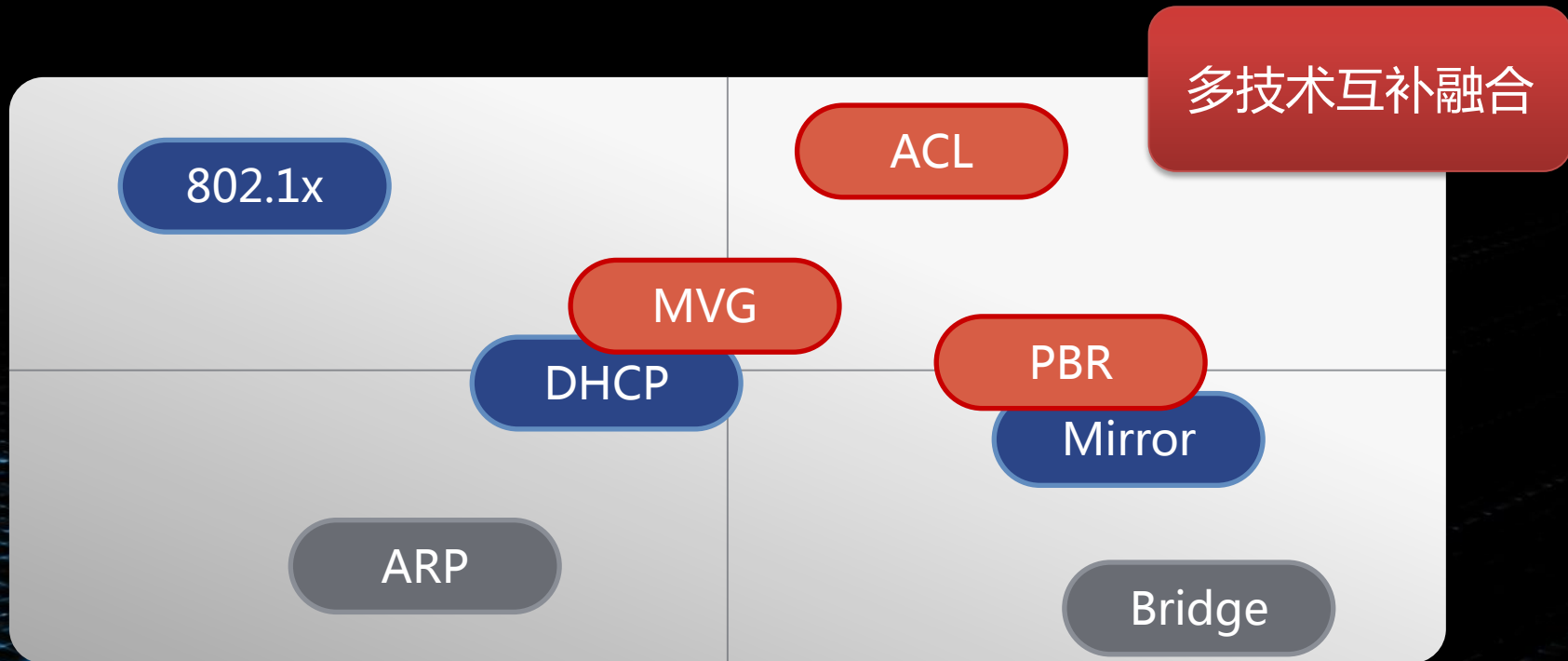
第一代

终端软件管控，ARP技术，有管控漏洞

下一代准入控制技术的4个技术维度

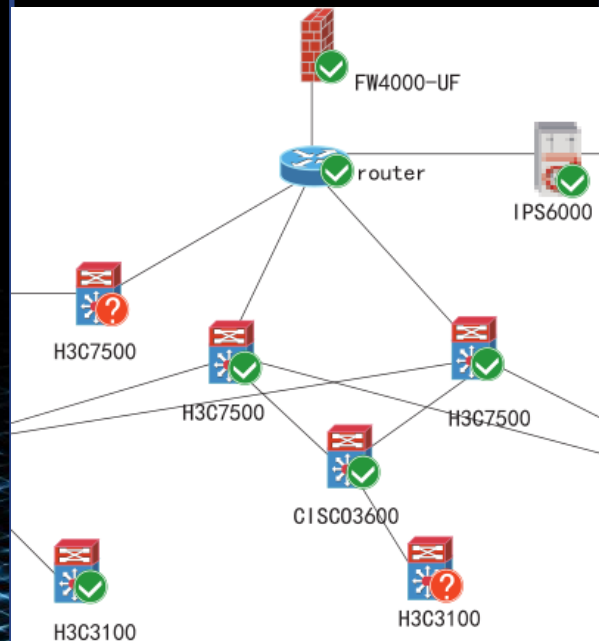


多种准入控制技术相结合

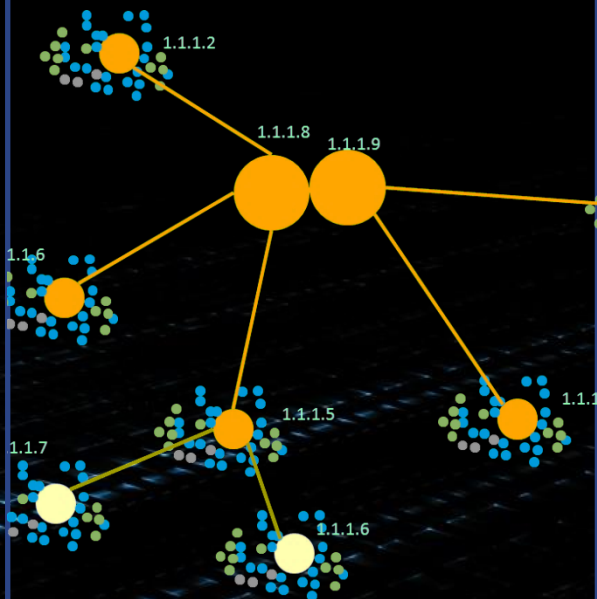


可视化的准入控制

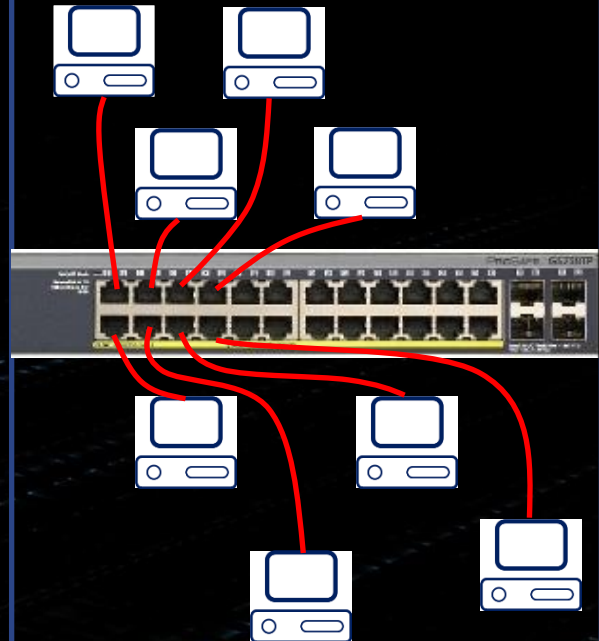
网络拓扑图



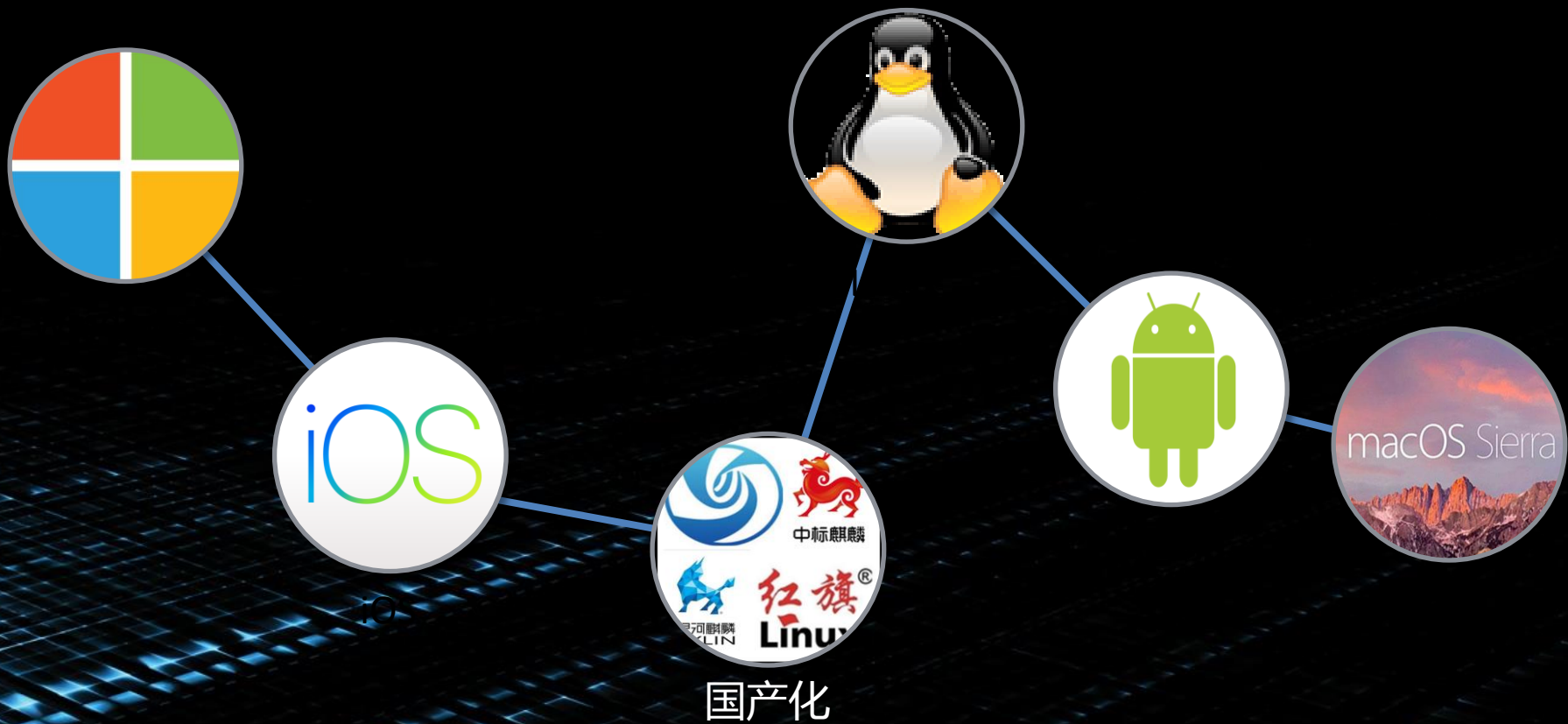
网络逻辑图



面板连接图



适应国内外主流操作系统



设备指纹识别



1

识别率大于95%

2

规则化智能识别

3

唯一标识抗伪造

落实《网络安全法》的相关条款要求

法律条款

国家实行 **网络安全等级保护制度**。

网络运营者应当按照网络安全等级保护制度的要求，履行下列安全保护义务，保障网络免受干扰、破坏或者未经授权的访问，防止网络数据泄露或者被窃取、篡改

准入控制的实现

1. 身份鉴别和自主访问控制
2. 边界防护
3. 完整性保护
4. 资源控制
5. 安全审计

落实《网络安全法》的相关条款要求

法律条款

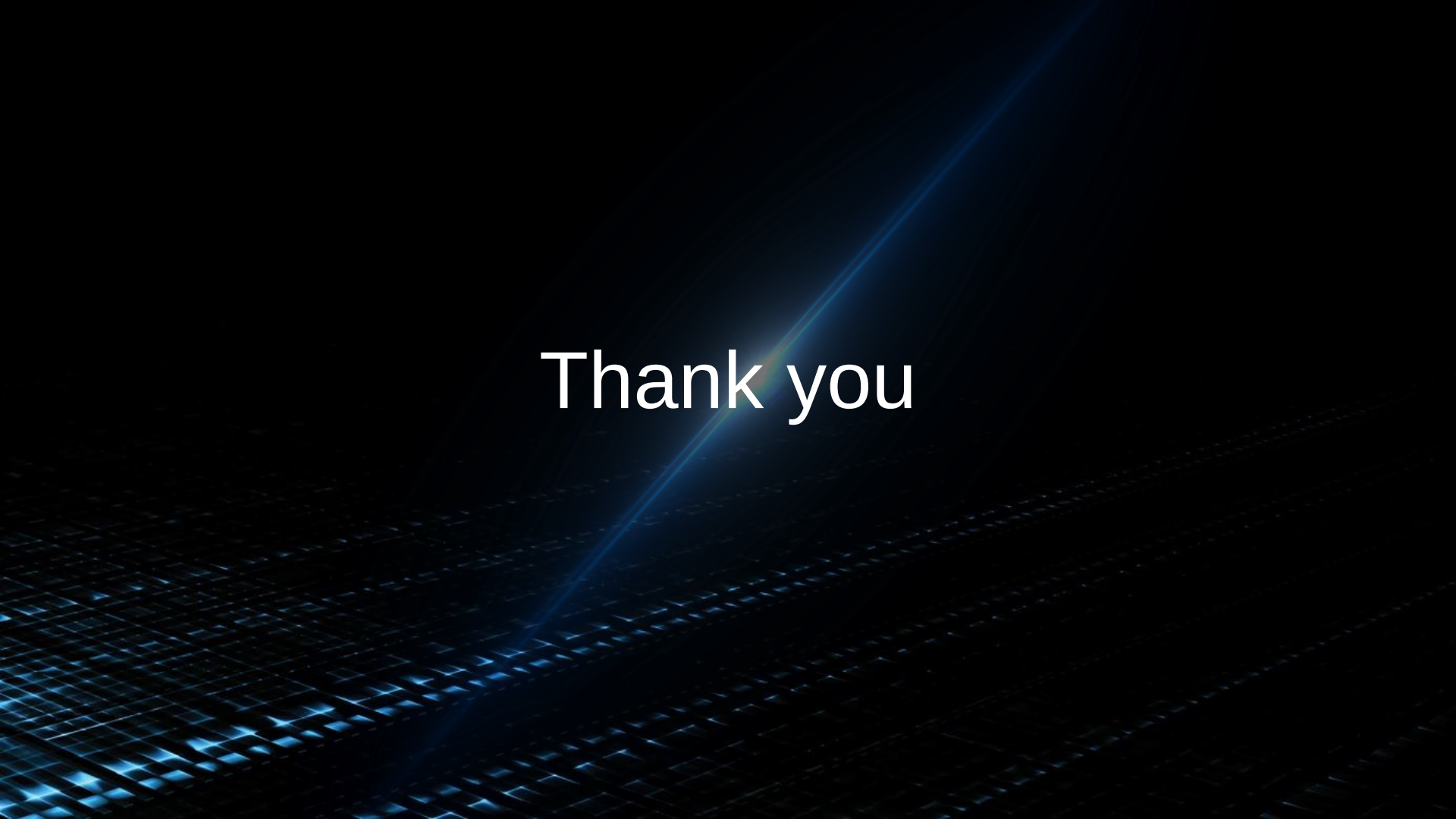
网络安全事件发生的风险增大时，省级以上人民政府有关部门应当按照规定的权限和程序，并根据网络安全风险的特点和可能造成的危害，采取下列措施：

（一）要求有关部门、机构和人员及时

收集、报告有关信息，加强对网络安全风险的监测；

准入控制的实现

1. 终端信息采集
2. 终端入退网信息
3. 终端认证信息
4. 终端安全状态

The background is a dark blue gradient. A bright, glowing grid pattern, resembling a wireframe or a digital mesh, is visible in the lower-left and bottom-center areas. A sharp, diagonal streak of light, transitioning from blue to white, cuts across the upper-right portion of the image.

Thank you